CARTA DE AUTORIZACIÓN Y REGLAS DE COMPROMISO

Implementación de un SOC Nivel 1 · Laboratorio académico

Caso	C05 — PagoClaro Fintech S.A.S.
Asignatura	Ética del Hacking / Ciberseguridad Defensiva
Docente	Julián Barney Jaimes Rincón
Estudiante	Nelson Enrique Sierra Perez

1. Partes

El cliente es PagoClaro Fintech S.A.S., organización ficticia representada para fines académicos por el docente Julián Barney Jaimes Rincón, en calidad de representante legal ficticio. El consultor es el estudiante responsable del parcial, identificado en el encabezado de este documento.

2. Objeto

Establecer las condiciones de autorización para diseñar, implementar y evaluar, exclusivamente en un laboratorio académico controlado, un Centro de Operaciones de Seguridad Nivel 1 (SOC N1) mediante Wazuh (SIEM), Kaspersky (EDR/XDR), GLPI (tickets e inventario), así como la comparación y cotización de un firewall de nueva generación (NGFW).

3. Alcance

El diseño comprende los 20 equipos de cómputo del caso C05 (11 Windows 11, 5 macOS y 4 Ubuntu Server), la infraestructura de red y los servicios cloud ficticios. La implementación representativa se desarrollará en máquinas virtuales propias: servidor Wazuh, estación Windows 11, servidor Ubuntu de pruebas y los componentes de gestión necesarios; GLPI se desplegará en una instancia cloud destinada al ejercicio. Quedan excluidos los sistemas reales de empresas, de la institución educativa, de terceros y toda infraestructura no autorizada.

3.1. Supuestos del laboratorio

Se utilizará VirtualBox con una red Host-only 192.168.56.0/24. El laboratorio contará con un servidor Wazuh, una estación Windows 11 y un servidor Ubuntu. Kaspersky utilizará una consola compatible local o en la nube, y GLPI funcionará en una instancia cloud. Los escenarios VPN serán simulados, el NGFW únicamente se cotizará y los 20 equipos empresariales estarán representados mediante inventario y un plan de despliegue.

4. Actividades permitidas

- Instalar y configurar las herramientas de monitoreo y protección sobre los activos propios incluidos en el alcance.
- Generar eventos de prueba controlados: autenticaciones fallidas, modificaciones de archivos vigilados, creación de usuarios ficticios y pruebas EICAR en endpoints del laboratorio.
- Analizar alertas, realizar triage y registrar tickets de incidentes simulados o generados en el laboratorio.
- Consultar fuentes públicas de reputación sin divulgar secretos ni datos confidenciales.

5. Actividades prohibidas

- Acceder, escanear o ejecutar ataques o pruebas de credenciales contra infraestructura ajena o fuera del alcance.
- Capturar tráfico de terceros o utilizar información financiera, transaccional o personal real.
- Deshabilitar controles de seguridad de equipos ajenos o comprometer la disponibilidad de sistemas externos.
- Publicar contraseñas, tokens, llaves, direcciones IP públicas reales u otras evidencias sensibles.

5.1. Horario de monitoreo y límites de actuación SOC N1

El horario propuesto será de lunes a viernes, de 8:00 a. m. a 5:00 p. m. El analista N1 podrá monitorear alertas, realizar triage, registrar incidentes y ejecutar acciones de contención previamente autorizadas. Los incidentes críticos, análisis forenses y modificaciones sensibles serán escalados al nivel N2.

6. Confidencialidad y protección de datos

Toda la información del ejercicio será ficticia. Los logs, capturas, configuraciones y tickets se manejarán como información restringida, con acceso limitado al estudiante y al docente. Se tomarán como referencias la Ley 1273 de 2009, la Ley 1581 de 2012, la Ley 1266 de 2008 y PCI DSS, según el contexto financiero del caso.

6.1. Clasificación de la información

Clasificación	Información
Pública	Información académica autorizada para divulgación.
Interna	Inventarios ficticios y procedimientos operativos.
Confidencial	Registros de seguridad, alertas e informes de incidentes.
Restringida	Contraseñas, tokens, claves y credenciales de administración.

7. Detención y comunicación

Ante un hallazgo real, una duda sobre el alcance o un efecto inesperado, el estudiante detendrá la actividad, conservará la evidencia mínima necesaria y contactará al docente por el canal académico establecido: nesierra@uts.edu.co.

8. Firmas

_____

Consultor / Estudiante
Nombre: Nelson Enrique Sierra Perez

_____

Representante académico / Docente
Julián Barney Jaimes Rincón